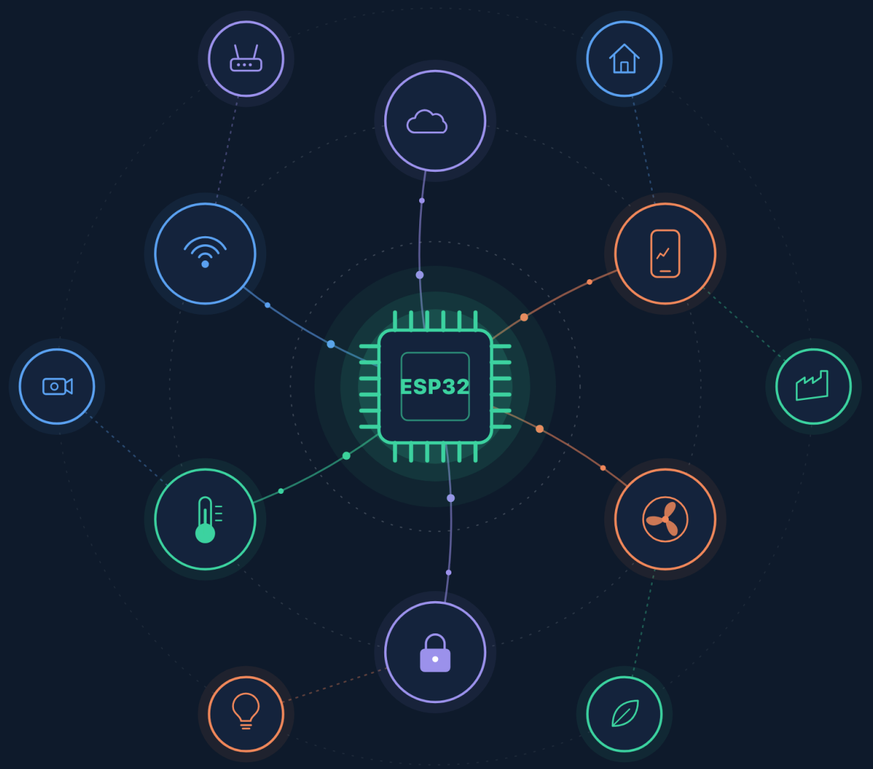
MODULE 7 · 45 MINUTES

IoT Security and Best Practices

Why a cheap sensor at a remote site can be the way in, the simple defences, and what to ask a vendor.



Mehdi Lotfinejad

Introduction to the Internet of Things

THE ROAD AHEAD

Eight modules, one Smart Site Monitor

PART 1 — DEVICES AND DATA

01
What is IoT?
Lecture

02
How it's built
Lecture

03
Sensors and actuators
Lab 2

04
Getting online
Lab 3

PART 2 — CLOUD, AUTOMATION AND SECURITY

05
Cloud and dashboards
Lab 4

06
Automation
Lab 5

07
Security
You are here

08
Real world + pitch
Lab 7

BY THE END OF THIS MODULE

You will be able to...

01 **Explain** why a cheap sensor at a remote site can be the way in

02 **Describe** simple defences: identity, separate networks, encryption

03 **Decide** who owns vendor risk, and what to ask before buying

04 **Review** the Smart Site Monitor before it goes onto tower sites

05 **Fill in** box 8 of your business-case canvas: the risks

Part A

How attackers get in

The tower site first, then two true stories.

OUR MAIN CASE · THE TOWER SITE

Security at a remote tower site

Shelter door

Who opened it, and when? Often nobody knows until the next visit.

Remote access

Contractors log in to the tower RMS from their own office.

Fuel and batteries

Diesel and batteries are valuable, and sites are far away.

Now we add a new device to every site: the IoT monitor. Is it a guard, or **another door**?

FOUR REASONS ATTACKERS LIKE IOT

Why IoT devices are easy targets

So many

Billions of devices, and many are identical.

Rarely updated

A weakness found in year one is still there in year five.

Rushed design

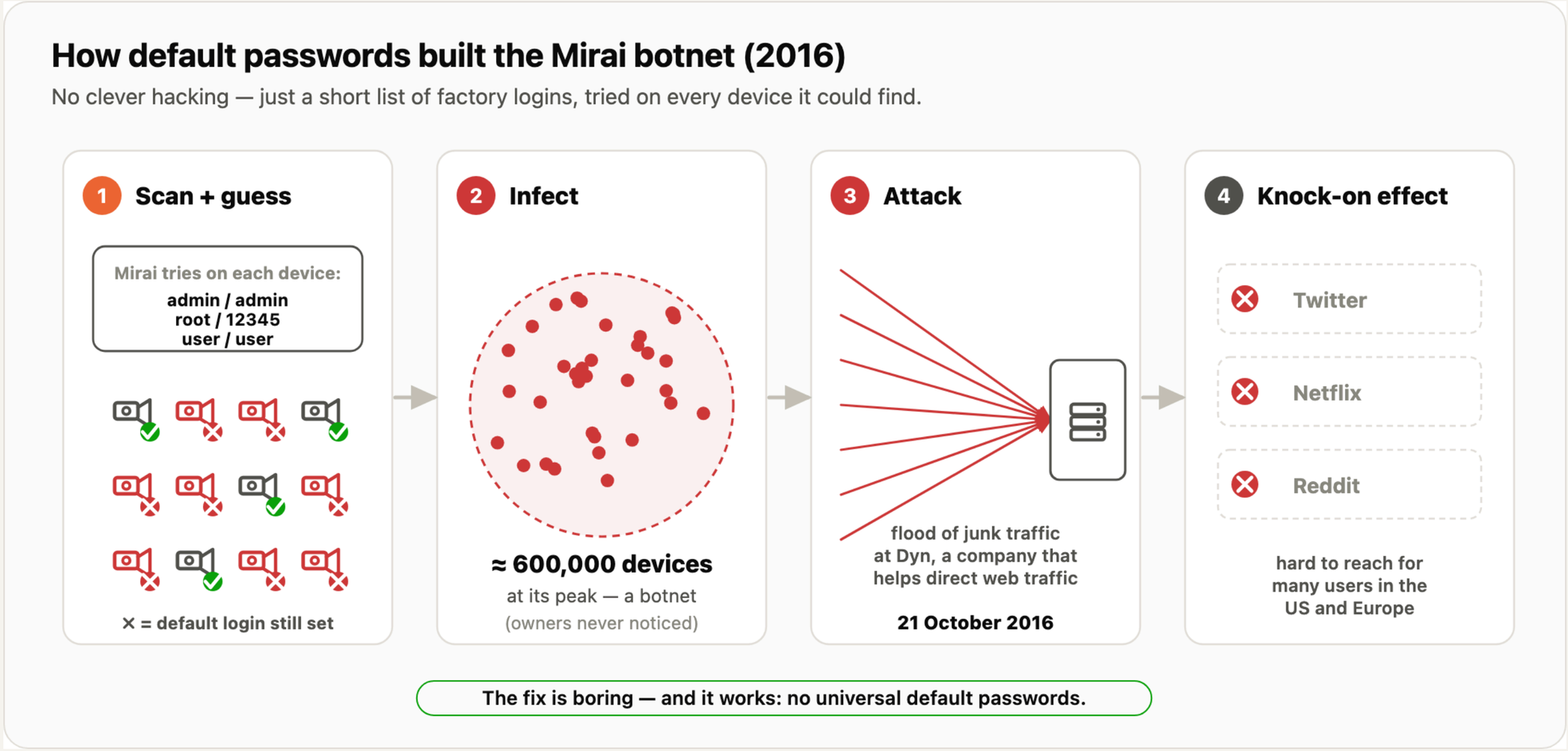
Weak passwords, old software, and no way to fix them.

Physical world

An attack can open a door, or hide a fuel theft.

TRUE STORY 1 · 2016

The Mirai botnet



TRUE STORY 2 · 2013

The Target breach



The contractor

A heating and cooling (HVAC) firm had a login to Target’s network.



The theft

Attackers stole that login from the contractor.



The way in

The breach began with that stolen login.

The weak point was a **supplier**, not Target itself. Source: Krebs on Security, 2014.



Photo: pslim, CC BY 2.0, via Wikimedia Commons

THIRD-PARTY RISK

Who else has a key to your site?

- The tower RMS provider
- The generator and battery maintenance team
- The fuel delivery contractor
- The cooling vendor in our data centres
- The sensor maker’s cloud

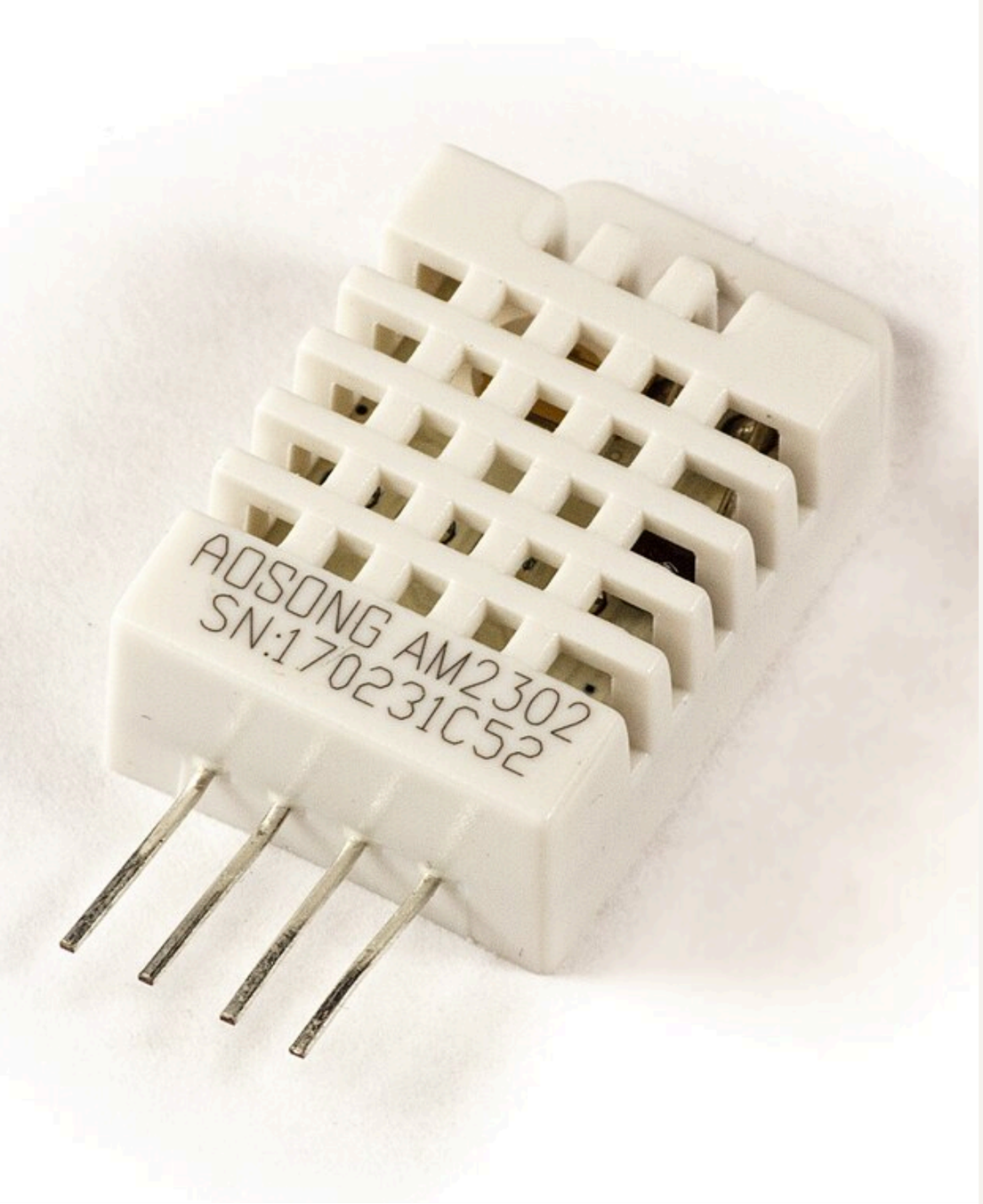


Photo: Ubahnverleih, CC0, via Wikimedia Commons

THE KEY IDEA TODAY

A cheap sensor can be the way in

- A sensor is a small computer on your network
- It often ships with a default password
- Nobody updates it, and nobody watches it
- From there, an attacker can reach other systems
- A fake reading can hide a hot shelter

PAUSE AND CHECK

A cheap sensor in the shelter at Tower Site 12 still has its factory password. Why is that a risk for the whole network?

Think of Mirai and Target. Talk to your neighbour for one minute.

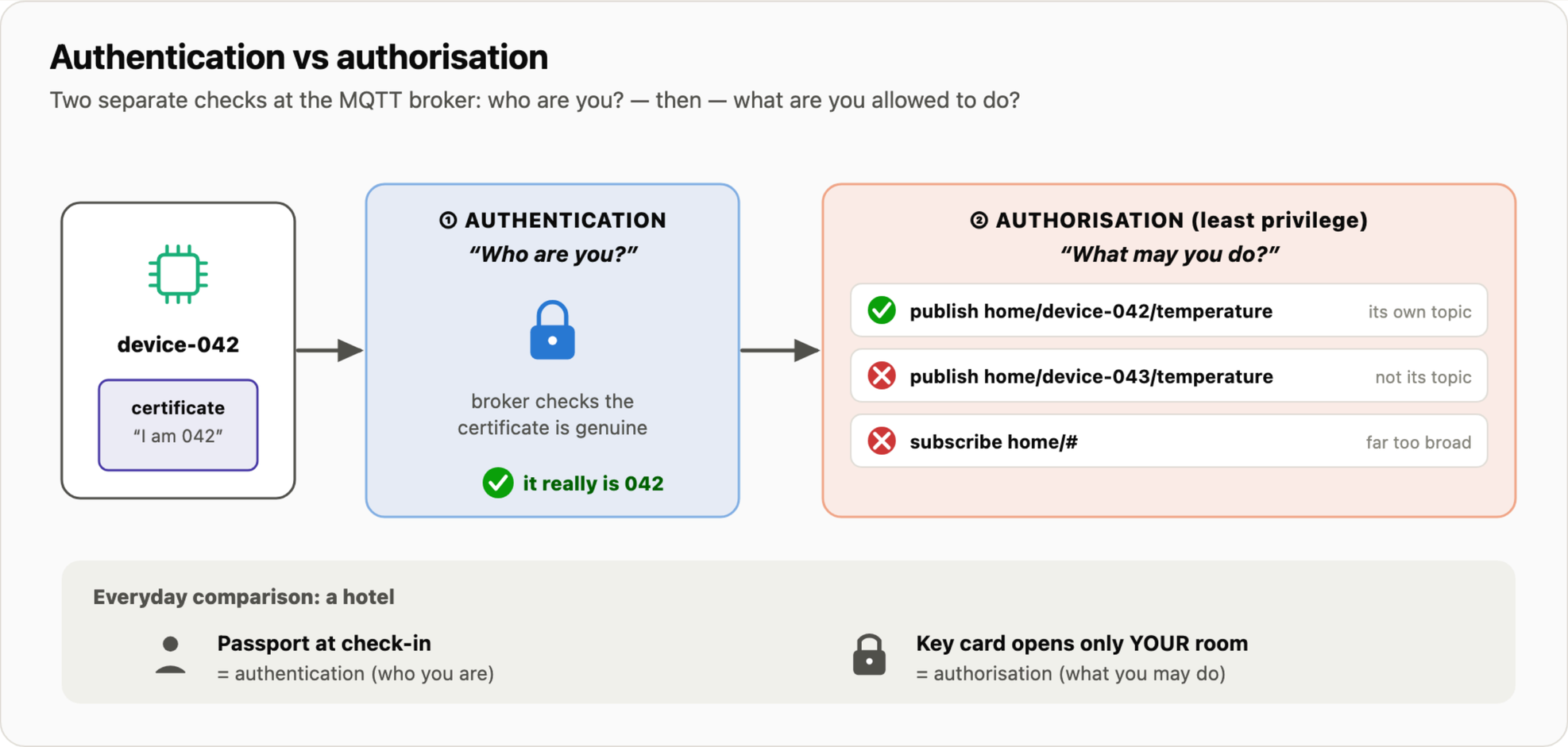
Part B

Simple defences

Strong identity, separate networks, encryption and updates.

DEFENCE 1 · IDENTITY

Authentication and authorisation



DEFENCE 2 · SEPARATE NETWORKS

Keep site systems off the office network

Office IT

Email, laptops and finance. Many users, many risks.

Site systems (OT)

Tower RMS, batteries, generators, doors; cooling and the BMS.

One guarded gate

A firewall lets only the traffic you need pass.

If a sensor is attacked, the attacker is stuck in one **zone**. The industrial standard IEC 62443 uses zones like this.

DEFENCES 3 AND 4 · PASSWORDS, ENCRYPTION, UPDATES

Securing the Smart Site Monitor

In the labs	At a real tower site
Public MQTT broker, no password	Our own broker; a unique login or certificate per device
Port 1883, not encrypted	Port 8883, encrypted with TLS
Any client can read iot-workshop/#	Each monitor uses only its own topics
Plain HTTP to ThingSpeak	HTTPS
Wi-Fi password written in the code	Secrets kept separately, never shared
No way to update the device	Signed updates, with a stated support period
On any Wi-Fi network	On the separate site (OT) network, via 4G

COMMON MISCONCEPTIONS

Four ideas that trip people up

✗ **Myth** *Our sensors are too small and boring to attack.*	✓ **Fact** Tools like Mirai scan the whole internet for any weak device.
✗ **Myth** *Security is the vendor’s problem.*	✓ **Fact** It’s shared. We must change passwords, update, control access.
✗ **Myth** *Encryption solves everything.*	✓ **Fact** It doesn’t stop weak passwords, fake updates or stolen keys.
✗ **Myth** *Once it’s secure, it stays secure.*	✓ **Fact** New weaknesses appear all the time. Devices need updates.

Part C

The business lens

Who owns the risk, what to ask a vendor, and what it means for telco operations.

THIRD-PARTY RISK

Who owns vendor risk?



One owner

One person in the business signs off each vendor.



Access list

Who can log in remotely, to what, and when.



On request

Switch vendor access on when needed, then off.



Remove on exit

When a contract ends, remove the login that day.

BEFORE YOU SIGN

Six questions to ask a vendor

Passwords?

Does each unit get its own password?

Encryption?

MQTT on port 8883 with TLS? HTTPS?

Updates?

Are they signed? For how many years?

Remote access?

Who on your side can log in, and how?

Our data?

Where is it kept? Can we take it with us?

Weaknesses?

How do we report one? How fast is the fix?

RULES THAT APPLY HERE

Security rules in Malaysia

Cyber Security Act

Act 854 (2024): critical sectors must assess risk and report incidents.

PDPA (2024)

Personal data, such as camera images: report a breach within 72 hours.

MCMC codes

Technical codes on IoT security, from MCMC.

A summary, not legal advice. Abroad: the UK PSTI Act and the EU Cyber Resilience Act.

TODAY → WITH IOT → THE BENEFIT

In telco operations

Today	With IoT, done safely	The benefit
Site access: a break-in is found at the next visit	A door contact alarms the NOC at once	Less theft, faster response
Vendor access: contractor logins stay open for years	One login per contractor, only for the job	Fewer open doors
Alarms: fuel loss is found late, or a reading is wrong	Encrypted, trusted fuel and battery alarms	Fewer wasted site visits

TEAM ACTIVITY · 10 MIN

Spot the vulnerability

1. Get into your **mixed teams of three**. Rotate roles.
2. Each team takes **2 of the 5 snippets**.
3. For each one: **what's wrong?** What's the **worst case**?
4. **How would you fix it?** Every fix is in this module.
5. Decision owner: **ready for tower sites**, or not yet?

DEBRIEF

Five snippets, five fixes

Wi-Fi on GitHub

Keep secrets in a separate file, never shared.

admin / admin

Force a new, unique password at setup.

Plain HTTP

Use HTTPS, and MQTT on 8883 with TLS.

One lock topic

Each lock gets its own identity and topic.

Unsigned update

Sign it, use HTTPS, check the signature.

All five are on the **OWASP IoT Top 10**, a free checklist of common IoT weaknesses.

BUSINESS-CASE CANVAS · 3 MIN

Canvas box 8: the risks

1. Take your team’s canvas and find **box 8: risks**.
2. **Security:** which door could an attacker use? Who has access?
3. **False alarms:** what if it alerts too often, or too late?
4. **Vendor lock-in:** can you change supplier and keep your data?
5. For each risk, write **one fix** and **one owner**.

KEY TAKEAWAYS

What to remember

- A cheap sensor at a remote site is a computer: it can be **the way in**
- Mirai: **default passwords** alone built a huge botnet
- Target: the way in was a **contractor’s login**
- **Authentication** proves who; **authorisation** limits what
- Keep **site systems (OT)** apart from office IT; **encrypt** MQTT
- **Vendor risk** needs an owner, and questions before you buy

CHECK YOUR UNDERSTANDING

Quick quiz

Q1 Name two security risks at a remote tower site.

Q2 Why did the Mirai botnet take over so many devices?

Q3 How did the Target breach begin? Who has a similar key to our sites?

Q4 Authentication or authorisation? Give a tower-site example of each.

UP NEXT · MODULE 8

Real-World IoT Applications and Project Showcase

Complete systems for tower sites and data centres, Lab 7, and your canvas pitch.

Mehdi Lotfinejad

Book, labs and slides: github.com/datatweets/intro-to-iot-workshop